UNIVERSIDADE FEDERAL
UFERSA
RURAL DO SEMI-ÁRIDO

Segurança e Segurança Funcional

Prof. Ferdinandy Chagas

Parte 1

Segurança Funcional (Safety)

O Que é Segurança Funcional (Safety)?

- **Definição:** A capacidade de um sistema de evitar entrar em estados que causem ou levem a danos, ferimentos ou perda de vidas.
- **Foco:** Prevenir falhas que tenham consequências catastróficas no mundo físico.
- **Exemplos Críticos:** Aviação (737 MAX), setor automotivo, sistemas médicos (Therac-25), usinas de energia.

Causas de Estados Inseguros

- **Omissão:** A falha de um evento ocorrer (ex: um valor de sensor não chega).
- **Comissão:** A ocorrência espúria de um evento indesejável.
- **Timing:** Um evento ocorre muito cedo ou muito tarde.
- **Valores Incorretos:** O sistema recebe ou calcula valores sutis ou grosseiramente incorretos.
- **Fora de Sequência:** Eventos chegam na ordem errada.

Cenário Geral de Segurança Funcional

- **Fonte:** Fonte de dados (sensor, componente), clock, ou ação do usuário.
- **Estímulo:** Omissão, comissão, dados incorretos ou falha de timing.
- **Artefato:** Porções críticas do sistema.
- **Resposta:** O sistema não entra em estado inseguro, ou retorna a um estado seguro, ou continua em modo degradado para minimizar danos.
- **Medida:** Tempo para retornar a um estado seguro, dano ou ferimento causado.

Exemplo de Cenário de Segurança Funcional

- **Cenário:** Um sensor em um sistema de monitoramento de paciente falha em reportar um valor crítico. A falha é registrada, uma luz de aviso acende e um sensor de backup (de menor fidelidade) é ativado. O sistema continua monitorando o paciente com o sensor de backup em menos de 300 ms.

Táticas de Segurança Funcional: Visão Geral

- Categorias:
  - Evitar
  - Detectar
  - Remediar (Conter e Recuperar) estados inseguros.

Categoria: Evitar Estado Inseguro

- **Objetivo:** Prevenir a entrada em um estado perigoso.
- **Táticas:**
  - **Substituição:** Usar mecanismos de proteção baseados em hardware (ex: watchdogs) em vez de software.
  - **Modelo Preditivo:** Prever o estado de saúde do sistema para dar um aviso prévio de problemas potenciais (ex: sistema anti-colisão de carro).

Categoria: Detectar Estado Inseguro

- **Objetivo:** Identificar quando o sistema entrou em um estado perigoso.
- **Táticas:**
  - **Timeout:** Detectar falhas de omissão e timing.
  - **Monitoramento de Condição:** Verificar condições e suposições de design (assertions).
  - **Verificação de Sanidade (Sanity Checking):** Validar a razoabilidade das operações ou dados.
  - **Comparação:** Comparar saídas de elementos replicados.

Categoria: Contenção

- **Objetivo:** Limitar os danos associados a um estado inseguro.
- **Subcategorias:**
  - **Redundância:** Manter cópias de componentes para assumir em caso de falha.
  - **Limitar Consequências:** Abortar operações, operar em modo degradado.
  - **Barreira:** Impedir que problemas se propaguem (ex: firewall, interlocks).

Tática de Contenção: Redundância

- **Ação:** Usar componentes redundantes para continuar a operação.
- **Tipos:**
  - **Replicação:** Clones idênticos (protege contra falhas de hardware, não de design).
  - **Redundância Funcional:** Diversidade de design para proteger contra falhas de modo comum.
  - **Redundância Analítica:** Diversidade de requisitos e componentes.

Tática de Contenção: Limitar Consequências

- **Ação:** Reduzir graciosamente a funcionalidade do sistema de forma planejada e segura.
- **Exemplos:**
  - **Abortar:** Interromper uma operação insegura antes que ela cause danos.
  - **Degradação:** Manter as funções mais críticas do sistema na presença de falhas.
  - **Mascaramento (Masking):** Usar votação entre componentes redundantes para mascarar uma falha.

Tática de Contenção: Barreira

- **Ação:** Conter problemas para que não se propaguem.
- **Táticas:**
  - **Firewall:** Limita o acesso a recursos especificados (processadores, memória, rede).
  - **Interlock:** Controla o sequenciamento correto de eventos para proteger componentes.

Categoria: Recuperação

- **Objetivo:** Colocar o sistema de volta em um estado seguro.
- **Táticas:**
  - **Rollback:** Reverter para uma cópia anterior de um estado bom conhecido.
  - **Reparar Estado:** Corrigir um estado errôneo e continuar a execução.
  - **Reconfiguração:** Remapear a arquitetura lógica para os recursos (potencialmente limitados) que ainda funcionam.

Padrão de Segurança: Sensores Redundantes

- **Estrutura:** Se um sensor é crítico para a segurança, ele deve ser replicado.
- **Benefício:** Protege contra a falha de um único sensor.
- **Trade-off:** Adiciona custo e complexidade para processar múltiplas entradas.

Padrão de Segurança: Monitor-Atuador

- **Estrutura:** Um componente **Monitor** verifica a razoabilidade dos comandos calculados por um **Controlador de Atuador** antes de enviá-los ao hardware.
- **Benefício:** Separa o cálculo do valor da verificação do valor, agindo como uma verificação redundante.
- **Trade-off:** O desenvolvimento e a manutenção do monitor consomem tempo e recursos.

Padrão de Segurança: Segurança Separada

- **Estrutura:** Dividir o sistema em porções críticas e não críticas para a segurança.
- **Benefício:** Reduz o custo de certificação, pois apenas a porção (geralmente pequena) crítica precisa passar por um rigoroso processo de validação.
- **Trade-off:** O trabalho de separação e de provar que não há influência da parte não crítica na crítica pode ser caro e difícil.

Níveis de Garantia de Design (DAL)

- Usado em aviônicos (DO-178C) para classificar funções de software com base nos efeitos de sua falha.
- **A: Catastrófico** (pode causar mortes, perda da aeronave)
- **B: Perigoso** (grande impacto negativo, pode causar ferimentos fatais)
- **C: Maior** (reduz significativamente a margem de segurança)
- **D: Menor** (inconveniência)
- **E: Sem Efeito**
- DALs ajudam a focar os recursos de teste e validação onde são mais necessários.

Parte 2

Segurança (Security)

Segurança

- **Segurança** é a medida da capacidade do sistema de proteger dados e informações contra acesso não autorizado, ao mesmo tempo em que fornece acesso a pessoas e sistemas autorizados.
- Um **ataque** é uma ação tomada contra um sistema com a intenção de causar danos.
- Foco em três características: **Confidencialidade, Integridade e Disponibilidade (CID)**.

Tríade CID

- **Confidencialidade**: A propriedade de que dados ou serviços são protegidos contra acesso não autorizado.
- **Integridade**: A propriedade de que dados ou serviços não estão sujeitos a manipulação não autorizada.
- **Disponibilidade**: A propriedade de que o sistema estará disponível para uso legítimo.

Privacidade

- Um tópico diretamente relacionado à segurança é a **privacidade**.
- A privacidade se refere a limitação de acesso a informações pessoais identificáveis (**PII**).
- A **LGPD** (Lei Geral de Proteção de Dados) regulamenta o tratamento de dados pessoais no Brasil.

Cenário Geral de Segurança

Um cenário de segurança pode ser descrito por:

- **Fonte**: Origem do ataque (humano, outro sistema).
- **Estímulo**: O próprio ataque (tentativa de acesso, modificação, etc.).
- **Artefato**: O alvo do ataque (serviços, dados, componentes).
- **Ambiente**: O estado do sistema durante o ataque (online, offline, etc.).
- **Resposta**: A reação do sistema para garantir CIA.
- **Medida de Resposta**: Como a resposta é medida (tempo de detecção, dados recuperados, etc.).

Táticas de Segurança

O objetivo das táticas de segurança é controlar a resposta a um ataque. Elas se enquadram em quatro categorias:

- **Detectar** ataques
- **Resistir** a ataques
- **Reagir** a ataques
- **Recuperar** de ataques

Detectar Ataques

- **Detectar Intrusão**: Comparar tráfego de rede ou padrões de requisição com assinaturas de comportamento malicioso.
- **Detectar Negação de Serviço (DoS)**: Comparar o padrão de tráfego com perfis históricos de ataques DoS conhecidos.
- **Verificar Integridade da Mensagem**: Usar checksums ou hashes para verificar a integridade de mensagens e arquivos.
- **Detectar Anomalias na Entrega de Mensagens**: Detectar ataques "man-in-the-middle" verificando tempos de entrega ou número de conexões.

Resistir a Ataques (1/3)

- **Identificar Atores**: Identificar a origem de qualquer entrada externa (usuários, sistemas) através de IDs, endereços IP, etc.
- **Autenticar Atores**: Garantir que um ator é quem ele diz ser, usando senhas, certificados digitais, biometria, etc.
- **Autorizar Atores**: Garantir que um ator autenticado tenha os direitos para acessar ou modificar dados ou serviços.

Resistir a Ataques (2/3)

- **Limitar Acesso**: Restringir o número de pontos de acesso aos recursos para minimizar a superfície de ataque (ex: DMZ).
- **Limitar Exposição**: Minimizar os efeitos de um dano, reduzindo a quantidade de dados ou serviços acessíveis por um único ponto.
- **Criptografar Dados**: Proteger a confidencialidade dos dados em trânsito e em repouso.

Resistir a Ataques (3/3)

- **Separar Entidades**: Limitar o escopo de um ataque através da separação física ou virtual de componentes.
- **Validar Entradas**: Filtrar, canonizar e sanitizar entradas para se defender contra ataques como SQL Injection e XSS.
- **Alterar Configurações de Credenciais**: Forçar a alteração de credenciais padrão ou exigir a renovação periódica de senhas.

Reagir a Ataques

- **Revogar Acesso**: Limitar severamente o acesso a recursos sensíveis se um ataque estiver em andamento.
- **Restringir Login**: Limitar o acesso de um computador específico após repetidas falhas de login.
- **Informar Atores**: Notificar operadores, pessoal ou sistemas cooperantes quando um ataque é detectado.

Recuperar de Ataques

Além das táticas de disponibilidade, duas táticas são importantes para a recuperação de segurança:

- **Auditoria**: Manter um registro de ações de usuários e sistemas para rastrear as ações de um invasor e criar melhores defesas.
- **Não Repúdio**: Garantir que o remetente de uma mensagem não possa negar o envio e o destinatário não possa negar o recebimento.

Padrões de Segurança: Intercepting Validator

- Insere um elemento "wrapper" entre a origem e o destino das mensagens.
- **Responsabilidade principal**: Verificar a integridade da mensagem.
- **Benefícios**: Pode cobrir a maioria das táticas de "detecção de ataque" em um único pacote.
- **Trade-offs**: Adiciona um custo de desempenho e requer manutenção constante para se manter atualizado.

Padrões de Segurança: Intrusion Prevention System (IPS)

- Um elemento autônomo que identifica e analisa atividades suspeitas.
- Se a atividade for aceitável, ela é permitida. Caso contrário, é prevenida e relatada.
- **Benefícios**: Abrange a maioria das táticas de "detecção" e "reação".
- **Trade-offs**: Custo de desempenho e necessidade de atualização constante do banco de dados de padrões.

Contato

E-mail: ferdinandy@ufersa.edu.br

Sala 35 - Bloco de Professores I

Horário de atendimento: Seg e Ter, 14h às 17h

CREDITS: This presentation template was created by **Slidesgo**, and includes icons by **Flaticon**, and infographics & images by **Freepik**

slidesgo